ENGINEERING RESEARCH CORPORATION LLC

Secure-by-Design Readiness for Software, Firmware, and Connected Products

What can your organization demonstrate about how securely its products are built? A ten-domain, evidence-gated assessment framework converting NIST SSDF, CISA Secure by Design, SBOM guidance, and binding law into a control-to-evidence matrix — with separate views for executives, assessors, and engineers, and a versioned standards register for a moving target.

ERC Flagship Report ERC-RPT-2026-004

Version 1.0 — Public draft for review

Publication date: October 27, 2026

Engineering Research Corporation LLC

Prepared by the ERC Research Program

Every requirement in this framework is typed by obligation force — binding law, contractual obligation, voluntary standard, or ERC-proposed control — and every piece of evidence is tested for currency, use, technical sufficiency, and connection to release decisions. Document existence alone earns nothing. This report assesses; it does not certify.

Document control and disclosures

Document control

Table i. Document-control record

Item	Detail
Report title	Secure-by-Design Readiness for Software, Firmware, and Connected Products
Report identifier	ERC-RPT-2026-004 (persistent identifier; DOI planned as the ERC program matures)
Edition and version	Edition 1, Version 1.0 — Public draft for review
Publication date	October 27, 2026
Authors	ERC Research Program (named contributors listed in the final release)
Editors	Assigned at final release; independent editorial and accessibility reviewers per ERC QA gates
Publication status	Public draft for review. Framework anchored to published law and standards with ERC-proposed controls labeled; practitioner validation scheduled before final release.
Contact and canonical page	Engineering Research Corporation LLC. The canonical report page for corrections, replacement versions, the control workbook, and the management checklist will be posted at the ERC publications site and cited in the final release.
Suggested citation	Engineering Research Corporation LLC (2026). *Secure-by-Design Readiness for Software, Firmware, and Connected Products*, ERC-RPT-2026-004, v1.0.
License and copyright	© 2026 Engineering Research Corporation LLC. Report text licensed CC BY 4.0 on final release; workbook and checklist under CC BY 4.0 and scripts under an OSI-approved license, unless a client contract requires otherwise.

Disclosures

Sponsor or client: None. ERC-initiated and self-funded. Future sponsorship will be disclosed on every distributed copy.

Conflicts of interest: This framework may support ERC advisory engagements. That commercial interest is disclosed; all instruments are published openly so any organization can perform the same assessment without ERC. ERC will not publicly rate any named organization.

No certification claim (explicit): This document does not certify, accredit, or approve any product, organization, or program, and must never be advertised as ERC certification. If ERC ever establishes an independently governed certification program, it will publish criteria, assessor qualifications, appeals procedures, surveillance requirements, and conflict-of-interest controls first — and this report will be revised to reference them. Until then, outputs are assessments of evidence, not certifications.

Not legal advice: This report distinguishes laws, contractual obligations, voluntary standards, and ERC-proposed controls as a matter of analytical method. It is not legal advice; obligation analysis for a specific product requires qualified counsel.

Editorial independence: Findings are reported regardless of commercial effect on any named vendor.

Product-name disclaimer: Tool, standard, and regulation names are designations of their respective owners, used for identification only.

Use of AI disclosure: This report was drafted with AI writing assistance under ERC staff direction. Every external claim was verified against the cited source before inclusion; framework-internal content is labeled as ERC analysis.

Abstract

Buyers, regulators, and investors increasingly demand evidence that connected products were built securely — but organizations lack a practical way to demonstrate secure-by-design readiness beyond attestations and policy documents. This report defines a ten-domain control-to-evidence assessment framework covering governance and accountability, security architecture, secure development, build systems and provenance, third-party dependencies and SBOMs, vulnerability handling and disclosure, release engineering and signing, firmware update mechanisms, product telemetry, and end-of-life planning. The framework anchors to authoritative sources — NIST's Secure Software Development Framework with its four practice groups and v1.2 public draft, CISA's Secure by Design principles and pledge, NTIA and CISA SBOM minimum elements, NIST SP 800-193 firmware-resiliency guidance, and binding laws including the EU Cyber Resilience Act, US FDA section 524B, and the UK PSTI regime — and explicitly separates legal obligations from contractual commitments, voluntary standards, and ERC-proposed controls. Every control specifies objective, applicability, expected implementation, acceptable evidence, maturity indicators, responsible function, common gaps, and cross-references. Evidence is tested for currency, use, technical sufficiency, and connection to release decisions; document existence alone earns no credit. Readiness is reported in four ordinal tiers per control, with heat-map output and no composite scores. The principal implication: secure-by-design readiness is demonstrable with inspectable evidence, and the evidence requirements are converging worldwide faster than most product organizations are adapting.

Keywords

secure by design; SSDF; NIST SP 800-218; SBOM; software supply chain security; firmware update; vulnerability disclosure; EU Cyber Resilience Act; FDA premarket cybersecurity; DevSecOps; product security assessment; procurement

ONE-PAGE DECISION SUMMARY — for product-security leaders and procurement

The decision. What can this organization demonstrate about how securely its software, firmware, and connected products are built — and which gaps create regulatory, contractual, market, or diligence exposure first?

What the anchored evidence establishes (October 2026). (1) NIST SSDF organizes secure development into four practice groups (PO, PS, PW, RV) and integrates with existing life cycles; SSDF v1.2 is in public draft since December 2025. (2) The US federal attestation mandate (M-22-18, 2022) was rescinded by M-26-05 in January 2026 in favor of risk-based assurance — contract regimes churn; engineering evidence persists. (3) CISA Secure by Design: April 2023 principles; May 2024 pledge with seven goals, 68 initial and 250+ signers by January 2025; voluntary and enterprise-software scoped. (4) Binding law has dates: EU CRA main obligations December 11, 2027, with vulnerability- and incident-reporting clocks (24 h / 72 h / 14 days) already live since September 11, 2026; FDA 524B requires premarket plans, SBOMs, and postmarket processes for cyber devices; UK PSTI has applied since April 29, 2024. (5) SBOM baseline is NTIA 2021; a CISA update was drafted in August 2025.

The framework. Ten domains — governance, architecture, development, build systems, dependencies and SBOM, vulnerability handling, release engineering, firmware updates, telemetry, end-of-life. Each control specifies objective, applicability, implementation, evidence, maturity indicators, owner, gaps, and cross-references. Four ordinal readiness tiers (R0 Absent, R1 Documented, R2 Operational, R3 Assured) with the anti-document rule: existence is not implementation. Output is a heat map by domain and obligation class — never a composite score. No certification is offered or implied.

What to do now (ERC recommendations). (1) Inventory products against obligation classes and markets. (2) Generate SBOMs per release build. (3) Rehearse the CRA 24/72-hour reporting clocks before they bind. (4) Verify firmware-update authentication and anti-rollback; publish support periods. (5) Bind every artifact to a release decision. (6) In procurement, request evidence by control, not assertion. (7) Track the standards register quarterly.

Limitations. Register churn (SSDF v1.2 and CISA SBOM elements pending; US federal policy reversed in 2026); classification needs counsel; framework not yet practitioner-validated; telemetry and EOL controls partly ERC-proposed and labeled as such.

Executive summary

Decision problem

Product-security leaders, engineering managers, procurement departments, and auditors must decide: what can this organization demonstrate about how securely its software, firmware, and connected products are built — and what must be fixed before a customer, regulator, or acquirer asks? Policy documents and attestations no longer answer that question; evidence does. This report supplies the control-to-evidence structure for producing and auditing that evidence.

Key findings

1. The authoritative voluntary framework is organized and versioned. NIST's SSDF organizes secure-development practices into four groups — Prepare the Organization (PO), Protect the Software (PS), Produce Well-Secured Software (PW), and Respond to Vulnerabilities (RV) — and is designed to integrate with existing life cycles rather than replace them [1][2]. NIST released an SSDF v1.2 initial public draft on December 17, 2025 [3][4]. Guidance changes; a versioned standards register is mandatory practice for any assessment.

2. The US federal attestation regime was rescinded and replaced with a risk-based approach. OMB M-22-18 (September 2022) required SSDF-based attestations from software producers serving federal agencies; M-23-16 (June 2023) updated it; CISA released the attestation form in March 2024. OMB M-26-05 (January 2026) rescinded M-22-18 and M-23-16, directing agencies to adopt risk-based software and hardware assurance while permitting continued use of the attestation form and SBOM resources [17][18][19]. *Interpretation:* contract-driven attestations can disappear with administrations; engineering evidence survives procurement cycles and remains what diligence-grade buyers should demand.

3. CISA's Secure by Design movement is voluntary but has become a market signal. The April 2023 whitepaper defined secure-by-design and secure-by-default principles [5]; the May 2024 pledge set seven goals with 68 initial signers, more than 250 by January 2025 [7][8][9]; the pledge covers enterprise software, not consumer IoT [7]. CISA and FBI published updated Product Security Bad Practices guidance in January 2025 — non-binding, but a named list of what markets increasingly treat as unacceptable [10].

4. Binding law is arriving with specific dates. The EU Cyber Resilience Act (Regulation (EU) 2024/2847) entered into force December 10, 2024; its main obligations apply from December 11, 2027, while reporting obligations for actively exploited vulnerabilities and severe incidents apply from September 11, 2026 — a 24-hour early warning, 72-hour notification, and 14-day final report [13][14]. FDA section 524B requires premarket cybersecurity plans, SBOMs, and postmarket vulnerability processes for cyber devices [15]. The UK PSTI regime has applied to consumer connectable products since April 29, 2024 [16].

5. SBOM guidance has a baseline and a pending update. NTIA published the SBOM minimum elements in July 2021 (data fields; practices and processes), and CISA published a

draft update in August 2025 building on it [11][12].

The framework in brief

Ten domains; each control specifies objective, applicability, expected implementation, acceptable evidence, maturity indicators, responsible function, common gaps, and cross-references to SSDF, CISA, SBOM guidance, and applicable law. Evidence is graded on four ordinal readiness tiers (R0 Absent, R1 Documented, R2 Operational, R3 Assured) with an explicit anti-document rule: existence is not implementation — artifacts must be current, used, technically sufficient, and connected to release decisions.

Confidence and limitations

High confidence that the mapped obligations and practices reflect the cited authorities, verified October 2026. Moderate confidence on any organization placement until an assessment runs. The framework will be revised when SSDF v1.2 finalizes and when CISA's 2025 SBOM elements finalize — both tracked in the versioned standards register (Appendix G). The US federal reversal in 2026 demonstrates why the register exists.

Principal implication

Regulatory deadlines — CRA reporting already live since September 2026; main obligations December 2027 — make secure-by-design evidence a near-term engineering deliverable, not a compliance abstraction. Organizations that build the evidence pipeline now meet both the law and the market with the same work.

Contents

Document control and disclosures **2**

Document control . . . 2

Disclosures . . . 2

Abstract **3**

Keywords . . . 3

Executive summary **5**

Decision problem . . . 5

Key findings . . . 5

The framework in brief . . . 6

Confidence and limitations . . . 6

Principal implication . . . 6

Contents **7**

List of tables . . . 9

1. Purpose and decision context **10**

1.1 Why this report exists . . . 10

1.2 Primary audiences and decisions . . . 10

1.3 Executive language . . . 10

2. Research questions **10**

3. Scope and definitions **11**

3.1 Scope . . . 11

3.2 The ten domains . . . 11

3.3 Definitions . . . 11

4. Methodology and framework construction **12**

4.1 Construction protocol . . . 12

4.2 Evidence-selection protocol for the supporting audit . . . 13

4.3 Calculation methods . . . 13

5. Standards landscape and obligations map **13**

5.1 Versioned standards register (summary; full register in Appendix G) . . . 13

5.2 The four obligation classes (analytical rule) . . . 14

5.3 Key dates worth engineering against . . . 14

6. The framework: domains, controls, and the evidence matrix 15

6.1 Readiness tiers and the anti-document rule . . . 15

6.2 Control-to-evidence matrix (summary: one lead control per domain) . . . 15

6.3 Applicability rules . . . 16

6.4 Worked exemplar: domain 5, control 5.2 (SBOM) . . . 16

7. Analysis, including competing interpretations 17

7.1 Competing interpretations and structural tensions . . . 17

7.2 Executive view: exposure and priority . . . 17

7.3 Assessor view: mappings and evidence requirements . . . 17

7.4 Engineer view: implementation detail . . . 18

7.5 Anti-gaming rules (shared) . . . 18

7.6 The M-26-05 lesson (Interpretation) . . . 18

8. Risks, limitations, uncertainty, and data gaps 18

8.1 Quality assurance gates applied to this report . . . 19

9. Recommendations 19

10. Conclusion 20

References 21

Appendix A: Evidence-request list 23

A.1 Universal requests . . . 23

A.2 By domain (abridged; the workbook carries the full list) . . . 23

Appendix B: Assessor interview guide (60–90 minutes) 23

Appendix C: Worked exemplar — third-party dependencies and SBOM (domain 5) 24

Appendix D: Management checklist (one page) 24

Appendix E: Accessibility conformance statement 25

Appendix F: Assessment operations 25

Appendix G: Versioned standards register (detail) 26

Appendix H: Obligation-type classification detail (ERC analysis) 26

Appendix I: Lead-control specifications for the remaining nine domains **27**

Appendix J: Worked tier-assignment example and procurement language (ERC-constructed) **29**

Appendix K: Cross-framework mapping (domain to SSDF, CISA, and law) **29**

Appendix L: Assessment scope tiers **30**

Appendix M: Executive heat-map mock-up **31**

Glossary and acronyms **31**

Change log **32**

Data and code statement **32**

List of tables

Table i. Document-control record 2

Table 1. Primary audiences and the decisions this report supports 10

Table 2. Research questions and where they are addressed 11

Table 6. Readiness tiers 15

Table 8. Control 5.2 (SBOM) at full specification 17

Table 11. Domain 5 controls at full specification 24

Table 12. Control workbook structure 26

Table 13. Versioned standards register (full) 26

Table 15. Worked example: control 6.1 tier assignment 29

Table 16. Cross-framework mapping by domain 30

Table 18. Executive heat-map structure (illustrative profile) 31

Table 19. Version history 32

1. Purpose and decision context

1.1 Why this report exists

Conclusion first. Secure-by-design is no longer a philosophy; it is a set of demonstrable practices with named authorities, dates, and evidence types. What is missing in most organizations is not intent but an evidence pipeline: artifacts that are current, technically sufficient, and connected to release decisions. This report supplies the control-to-evidence structure to build and audit exactly that.

This is ERC's fourth flagship report and the demonstration of a core competency: converting complex standards into a practical, evidence-based assessment rather than summarizing cybersecurity guidance. The deliverables are: a ten-domain framework where every control is traceable to an authority and typed by obligation force; a control-to-evidence matrix with anti-gaming rules; three audience views (executive, assessor, engineer); and a versioned standards register acknowledging that the ground moves.

1.2 Primary audiences and decisions

Table 1. Primary audiences and the decisions this report supports

Audience	Decision this report supports
Product-security leaders	Which gaps create near-term exposure (regulatory, contractual, market) and the remediation order
Engineering managers and DevSecOps teams	What to implement and what evidence each practice must produce
Embedded and IoT manufacturers	What firmware-update, telemetry, and end-of-life obligations imply for product architecture
Procurement departments	What to demand from suppliers, and what evidence to accept
Government contractors	What remains contractually required after M-26-05, and how to stay ahead of agency risk determinations
Auditors and technical investors	An inspectable, repeatable assessment method with evidence-gating

1.3 Executive language

Business exposure is framed as: inability to sell into markets (regulatory), loss of procurement eligibility (contractual), incident and recall exposure (operational), and diligence failure (transactional). Engineering sections carry the technical precision; the two registers are separated by section and by appendix.

2. Research questions

Governing point. Eight questions structure the report. Each is answered or explicitly left unresolved.

Table 2. Research questions and where they are addressed

#	Research question	Addressed in
RQ1	What must organizations be able to demonstrate across the ten secure-by-design domains?	Section 6
RQ2	Which authority governs each requirement — law, contract, voluntary standard, or ERC-proposed control?	Section 5, Appendix H
RQ3	What evidence does each control require, and what distinguishes existence from effective implementation?	Sections 6, 7
RQ4	How do SSDF practice groups, CISA principles, SBOM guidance, and binding laws map onto the domains?	Section 5
RQ5	How should readiness be graded without false precision or document-count gaming?	Sections 6, 7
RQ6	What differs for executives, assessors, and engineers in consuming the same assessment?	Section 7
RQ7	How should remediation be sequenced against known regulatory dates?	Section 9
RQ8	What limits the framework validity, and what revisions are pending?	Section 8, Appendix G

3. Scope and definitions

3.1 Scope

In scope: software products and services; firmware; connected (IoT-class) products; the build and release infrastructure behind them; and the postmarket lifecycle (vulnerability handling, updates, telemetry, end-of-life).

Out of scope: organization-wide IT security programs (ISO 27001-style ISMS scope); cloud-infrastructure hardening as such; product safety certification; and any certification claim (see Disclosures).

3.2 The ten domains

The framework covers ten domains: 1 governance and accountability; 2 security architecture and threat modeling; 3 secure development practices; 4 build systems and provenance; 5 third-party dependencies and SBOM; 6 vulnerability handling and disclosure; 7 release engineering and signing; 8 firmware update mechanisms; 9 product telemetry and security monitoring; 10 end-of-life planning.

3.3 Definitions

Table 3. Key definitions

Term	Definition
SSDF practice groups	PO (Prepare the Organization), PS (Protect the Software), PW (Produce Well-Secured Software), RV (Respond to Vulnerabilities)
SBOM	A formal record of components and supply-chain relationships in software; NTIA minimum elements define baseline data fields and practices
Provenance	Verifiable information about how and where a build artifact was produced (builder, inputs, process)

Term	Definition
VDP	Vulnerability disclosure policy authorizing good-faith testing and defining reporting and handling
Cyber device	An FDA term of art under section 524B(c) for devices meeting specified software and cyber criteria
Product with digital elements	The EU CRA term for hardware or software products with an intended connection capability, direct or indirect
Readiness tiers	R0 Absent; R1 Documented; R2 Operational; R3 Assured (Section 6.1); ordinal, never averaged
Anti-document rule	Document existence is not effective implementation; evidence must be current, used, technically sufficient, and connected to release decisions
Obligation classes	Binding law; contractual obligation; voluntary standard or guidance; ERC-proposed control
Standards register	A versioned record of referenced instruments with dates, statuses, and change-watch triggers

4. Methodology and framework construction

Governing point. Every control traces to a named authority and is typed by obligation force. Nothing is presented as best practice without a source or an explicit ERC label.

4.1 Construction protocol

Step 1 — Anchor to SSDF structure. Domains and controls are cross-referenced to SSDF practice groups PO, PS, PW, and RV, which NIST designed for integration into existing life cycles [1].

Step 2 — Add product-lifecycle domains the SSDF does not cover. Firmware update mechanisms, product telemetry, and end-of-life planning are product obligations (CRA, FDA 524B, UK PSTI) rather than pure development practices; they form distinct domains anchored to those authorities and to NIST SP 800-193 for firmware resiliency [20].

Step 3 — Type every requirement by obligation force in four classes (Section 5.2): binding law; contractual obligation; voluntary standard or guidance; ERC-proposed control. This implements the report’s core analytic rule.

Step 4 — Specify controls with eight fields. Objective, applicability, expected implementation, acceptable evidence, maturity indicators, responsible function, common gaps, cross-references. Controls missing any field were revised.

Step 5 — Evidence-gating. Document existence earns R1 only. R2 requires the artifact to be current, technically sufficient, and demonstrably used in release decisions. R3 requires independent verifiability: provenance checks, reproducible builds, or attestation backed by inspectable artifacts.

Step 6 — Practitioner validation (scheduled). Before final release, structured interviews with practitioners across at least four sectors (enterprise software, IoT and embedded, medical devices, federal suppliers) will test control fit and evidence realism; revisions will be

published. No interview claims are made in this draft.

4.2 Evidence-selection protocol for the supporting audit

Search dates: October 20–27, 2026. Sources: NIST CSRC; CISA; EUR-Lex and the European Commission digital-strategy pages; FDA; GOV.UK; NTIA; the White House (OMB memoranda).

Search concepts: SSDF practice groups; secure by design pledge goals; SBOM minimum elements; Cyber Resilience Act application dates; FDA cyber device requirements; PSTI security requirements; software attestation memoranda.

Inclusion: official text or official landing pages only, for laws and frameworks. **Exclusion:** commentary as primary evidence for obligation content.

Conflict treatment: where instruments overlap — for example SBOM elements in NTIA 2021 versus the CISA 2025 draft — the register records both with versions and statuses; the framework cites the stricter, applicable one per obligation type.

4.3 Calculation methods

No statistics are computed. The assessment workbook performs inspectable arithmetic only: per-control tier assignment, gate checks, and heat-map aggregation by counts. No weighted composite scores exist anywhere in the framework.

5. Standards landscape and obligations map

Governing point. Confusing a pledge with a law — or a draft with a final standard — produces both wasted spending and unmet obligations. The two tables below separate them.

5.1 Versioned standards register (summary; full register in Appendix G)

Table 4. Versioned standards register (summary)

Instrument	Version / date	Status as of October 2026	Obligation type
NIST SSDF (SP 800-218)	v1.1, Feb 2022	Final, current	Voluntary standard; contractually invoked
NIST SSDF Rev.1	v1.2 IPD, Dec 17 2025	Draft (public comment)	Voluntary (future)
CISA Secure by Design whitepaper	Apr 2023	Published guidance	Voluntary guidance
CISA Secure by Design Pledge	May 2024; 7 goals; 68 initial, 250+ signers by Jan 2025	Active, voluntary	Voluntary commitment (signers only)
CISA/FBI Product Security Bad Practices	Updated Jan 17 2025	Published, non-binding	Voluntary guidance
NTIA SBOM Minimum Elements	Jul 12 2021	Final, baseline	Voluntary; contractually invoked

Instrument	Version / date	Status as of October 2026	Obligation type
CISA 2025 SBOM Minimum Elements	Draft Aug 22 2025	Draft (comment closed Oct 3 2025)	Voluntary (future)
NIST SP 800-193	May 2018	Final, current	Voluntary standard
EU Cyber Resilience Act	Reg (EU) 2024/2847; in force Dec 10 2024	Binding law	Law (EU market)
FDA section 524B	FD&C; Act; FAQ guidance updated Jun 2025	Binding law	Law (US medical devices)
UK PSTI regime	Act 2022; effective Apr 29 2024	Binding law	Law (UK consumer connectables)
OMB M-22-18 / M-23-16	2022 / 2023	Rescinded by M-26-05, Jan 2026	Former contractual driver (US federal)
OMB M-26-05	Jan 23 2026	Current US federal policy	Contractual driver (US federal, risk-based)

(All entries verified against official sources in October 2026; the register is versioned so future revisions of this report can update rows without re-basing the framework.)

5.2 The four obligation classes (analytical rule)

1. Binding law — obligations with legal force in a market (EU CRA; FDA 524B; UK PSTI). Non-compliance has legal consequences; scope and dates are statute-specific.

2. Contractual obligation — requirements imposed by buyers or programs (federal acquisitions under current OMB policy; enterprise contracts invoking SSDF or SBOM delivery). Enforceable between parties only.

3. Voluntary standards and guidance — SSDF, SP 800-193, CISA principles, SBOM minimum elements. Adoption is optional; market and reputational effects are real but not legal effects.

4. ERC-proposed controls — practices ERC adds beyond the anchors, labeled [ERC] throughout and never conflated with the above. (This classification implements the requirement to keep laws, contracts, voluntary standards, recommendations, and ERC proposals distinct; classification judgments for specific products require counsel — Appendix H.)

5.3 Key dates worth engineering against

Table 5. Obligation dates and scopes

Date	What begins	Applies to
Sept 11, 2026	EU CRA reporting of actively exploited vulnerabilities and severe incidents: 24-hour early warning, 72-hour notification, 14-day final report	Manufacturers placing products with digital elements on the EU market
Dec 11, 2027	EU CRA main obligations: essential cybersecurity requirements, vulnerability handling through the support period, SBOM availability where required	Same scope

Date	What begins	Applies to
Continuous	FDA 524B requirements attach to premarket submissions for cyber devices	US medical-device manufacturers
Apr 29, 2024 (in force)	UK PSTI: no universal default passwords; vulnerability disclosure policy; compliance statement	UK consumer connectable products
Program-specific	US federal: risk-based assurance per M-26-05; attestation form and SBOM elements remain available resources	Software producers to US federal agencies

6. The framework: domains, controls, and the evidence matrix

6.1 Readiness tiers and the anti-document rule

Table 6. Readiness tiers

Tier	Name	Meaning	Gate
R0	Absent	No artifact or practice	—
R1	Documented	An artifact exists	Existence only; explicitly not evidence of effective implementation
R2	Operational	Artifact is current, technically sufficient, and demonstrably used in release decisions	Currency check plus decision-record citation plus sufficiency review
R3	Assured	R2 plus independent verifiability	Reproducible builds, provenance verification, or attestation backed by inspectable artifacts

(ERC framework; the R1-is-not-implementation rule is the framework's central anti-gaming device, stated in every deliverable.)

6.2 Control-to-evidence matrix (summary: one lead control per domain)

The workbook carries all controls — two to four per domain — with all eight fields. Each row below shows the lead control and its primary evidence.

Table 7. Control-to-evidence matrix (lead control per domain)

#	Domain	Lead control (expected implementation)	Primary evidence	Anchors
1	Governance and accountability	Named executive owns product-security outcomes; security requirements flow into product requirements	Security policy with named owner; requirement-traceability entries; org-chart evidence	SSDF PO; CISA SbD ownership principle
2	Security architecture and threat modeling	Threat model per product and major release; mitigations tracked to closure	Threat-model artifacts; mitigation tracker linked to requirements	SSDF PW; CISA SbD

#	Domain	Lead control (expected implementation)	Primary evidence	Anchors
3	Secure development practices	Secure-coding standards; memory-safety roadmap; code review; secret hygiene	Review records; memory-safe roadmap; scan results; branch-protection settings	SSDF PW; CISA pledge goals; Bad Practices guidance
4	Build systems and provenance	Hardened, access-controlled build environment; build provenance produced and verified	Build logs; provenance attestations; environment-access records	SSDF PO/PS; federal risk-based guidance
5	Third-party dependencies and SBOM	Dependency inventory generated per build; SBOM meets minimum elements; known-vulnerability screening	Per-release SBOMs; dependency-update and screening records	NTIA/CISA SBOM elements; SSDF PS/PW; FDA 524B; CRA
6	Vulnerability handling and disclosure	Published VDP; intake, triage, remediation SLAs; CVE issuance practice	VDP; triage records; patch metrics; CVE records	SSDF RV; CISA pledge; UK PSTI; FDA 524B
7	Release engineering and signing	Signed release artifacts; signatures verified at update; release records with security checks	Signing procedure and logs; verification evidence; release checklists	SSDF PS; NIST SP 800-193 alignment
8	Firmware update mechanisms	Authenticated updates with anti-rollback; update delivery process with support-period commitment	Update-mechanism test records; rollback-protection evidence; support-period policy	NIST SP 800-193; EU CRA; UK PSTI
9	Product telemetry and security monitoring	Security-relevant telemetry defined; privacy-preserving collection; monitoring for in-field compromise	Telemetry data dictionary; monitoring runbooks; incident-drill records	CRA reporting readiness; [ERC] control
10	End-of-life planning	Published support-period and end-of-life policy; decommissioning and data-clearing guidance	EOL policy; last-update commitments; customer-notification records	EU CRA support-period duty; UK PSTI; [ERC] control

(All rows: ERC framework anchored to the cited authorities; bracketed labels mark ERC-proposed content.)

6.3 Applicability rules

Not every control applies to every product. The workbook applicability field states, per control: enterprise software (CISA pledge scope); on-premises software; SaaS; embedded firmware products; connected consumer products (UK PSTI scope); cyber devices (FDA scope); and EU-market products (CRA scope). A control scored not-applicable must carry the scope justification; not-applicable rows are excluded from tier counts rather than scored zero.

6.4 Worked exemplar: domain 5, control 5.2 (SBOM)

Table 8. Control 5.2 (SBOM) at full specification

Field	Specification
Objective	Buyers and responders can determine which components are in a shipped build, to act on vulnerabilities
Applicability	All software-bearing products; SBOM delivery legally attached to FDA cyber-device submissions and required under the CRA where specified
Expected implementation	SBOM generated automatically per release build from the dependency system of record; machine-readable format; distributed with the release or on request per contract
Acceptable evidence	Per-release SBOMs meeting NTIA minimum elements (or the final CISA 2025 elements when adopted); generation automation; a record of acting on an SBOM finding
Maturity indicators	R1: one SBOM exists. R2: SBOMs for the last three releases; automation evident; SBOM findings routed to triage. R3: SBOM verifiable against build provenance; customer delivery demonstrated
Responsible function	Product security plus build engineering; delivery owned by release management
Common gaps	SBOM generated once for an audit and never regenerated; hand-maintained lists; no linkage to vulnerability triage; components listed without versions
Cross-references	SSDF PS/PW; NTIA 2021; CISA 2025 draft; FDA 524B; EU CRA

(Appendix C works the full domain with its other controls; the workbook carries the remaining nine domains at the same depth.)

7. Analysis, including competing interpretations

7.1 Competing interpretations and structural tensions

Governing point (Interpretation). The same assessment supports three different conclusions depending on who is reading and what they must decide — and two structural tensions in the evidence base deserve explicit treatment before the audience views: (1) **voluntary momentum versus binding deadlines:** CISA’s pledge movement is voluntary and enterprise-software-scoped, while the CRA’s binding obligations reach all product classes on fixed dates; organizations optimized for pledge optics may still miss legal duties. (2) **attestation durability:** the US federal swing from mandatory SSDF attestation (M-22-18) to rescission and risk-based discretion (M-26-05) shows contract regimes churning while engineering evidence persists — the framework therefore scores evidence, not attestations.

7.2 Executive view: exposure and priority

Executives receive: the ten-domain heat map in readiness tiers; the obligation-typed gap list — what is legally required by when, what is contractual, what is market-driven; remediation sequencing with cost bands; and plain-language statements of what failure means: market access, procurement eligibility, incident liability, transaction risk. Executives never receive tier averages or percentages of compliance.

7.3 Assessor view: mappings and evidence requirements

Assessors receive: the full matrix with SSDF, CISA, and law cross-references per control; the evidence-request list (Appendix A); interview prompts (Appendix B); the anti-gaming rules

(Sections 6.1 and 7.5); and the conflict rule — the artifact governs over assertion, and discrepancies are recorded.

7.4 Engineer view: implementation detail

Engineers receive, per control: the expected implementation, tool-agnostic patterns, example artifact structures — for instance, what a decision-citing SBOM finding record looks like — and the maturity indicators to self-check. The engineer view is where the framework becomes a build list rather than a scorecard.

7.5 Anti-gaming rules (shared)

1. Existence is R1, never R2.

2. R2 requires a release-decision citation; "we use it" without a record is R1.

3. R3 claims require independent verification; self-attestation without supporting artifacts is R2.

4. Evidence older than one release cycle or twelve months expires.

5. The artifact governs over interview assertion; discrepancies are recorded.

6. No composite scores; report tier counts per domain and per obligation class.

7.6 The M-26-05 lesson (Interpretation)

Between September 2022 and January 2026, the primary US federal driver for SSDF evidence went from mandatory attestation to rescission and risk-based discretion. Organizations that built evidence pipelines kept everything of value — SBOMs, signing, VDPs, decision records serve every buyer — while organizations that built only the attestation document were left holding paper. This report’s evidence-first, obligation-typed design is the direct answer to that churn: the engineering artifacts are the durable layer; the regimes come and go.

8. Risks, limitations, uncertainty, and data gaps

Lead point. The standards register is the report’s most load-bearing component precisely because the landscape has already moved twice during this program — SSDF v1.2 drafted, CISA SBOM elements drafted, and the US federal attestation mandate rescinded.

Table 9. Limitations, consequences, and mitigations

Limitation	Consequence	Mitigation
Standards-register churn	Assessments can go stale	Versioned register (Appendix G); report re-basing policy; change log
Obligation-type classification needs legal judgment	Misclassification risk	Classification labeled as ERC analysis; counsel required for product-specific determinations (Appendix H)
Evidence realism varies by organization size	Small firms may meet substance with thinner artifacts	Tailoring guidance; score what exists, not what a large firm would produce

Limitation	Consequence	Mitigation
CRA implementing guidance still developing	Detail may shift before December 2027	Register tracks official EU sources; the framework cites regulation text, not commentary
Framework not yet practitioner-validated	Possible domain misfit	Scheduled interviews across four sectors; revisions published
Telemetry and end-of-life controls partly ERC-proposed	Buyers may treat them as mandatory	[ERC] labels; the obligation-type table prevents conflation
Self-assessment inflation	Unreliable profiles	R2 and R3 gates require decision records and independent verification; claimed-only evidence caps at R1
No certification offered	Buyer confusion	Explicit no-certification statement in Disclosures and every deliverable

8.1 Quality assurance gates applied to this report

Editorial review. Title matches scope; the executive summary agrees with the body; every research question is answered or explicitly unresolved; conclusions stay within the evidence; obligation types are labeled throughout; neutral naming; acronyms defined at first use.

Source audit. Every link cited was opened and checked against the exact claim during preparation (access dates October 2026). All legal and framework entries are official texts or official landing pages; commentary and vendor pages are excluded from obligation-content claims entirely.

9. Recommendations

Lead point (Recommendation). Build the evidence pipeline against the nearest binding date, not the loudest headline. The obligations have dates; the work is the same regardless of which driver matters most to your market.

Table 10. Recommendations with owner, priority, and prerequisites

#	Recommendation	Owner	Priority / prerequisites
1	Inventory products against the four obligation classes and applicable markets (EU, US federal, US medical, UK consumer); record the register row per product	Product security plus counsel	P1; prerequisite: product list
2	Stand up SBOM generation per release build (domain 5) — it serves CRA, FDA, and federal needs simultaneously	Build engineering	P1
3	Implement the vulnerability pipeline: VDP, triage SLAs, patch metrics — and rehearse the 24/72-hour CRA reporting clocks with an exercise before they bind	Product security plus incident response	P1 for EU-market products
4	Verify firmware-update authentication and anti-rollback per SP 800-193; publish support-period commitments (domains 7, 8, 10)	Firmware engineering	P1 for connected products
5	Bind every artifact to a release decision (R2 gating): introduce a release checklist that cites SBOM, threat-model, scan, and update-test artifacts	Release management	P2

#	Recommendation	Owner	Priority / prerequisites
6	In procurement, request evidence by control, not by assertion: SBOMs per release, VDP, provenance samples; accept tier labels with artifact references	Procurement	P2
7	Track the standards register quarterly; re-baseline the assessment when SSDF v1.2 and the CISA SBOM elements finalize	Product security	P2

Distinguishing mandatory from recommended. For EU-market connected products, CRA reporting (since September 2026) and essential requirements (from December 2027) are mandatory; for US medical devices, 524B requirements attach to submissions; for UK consumer connectables, PSTI duties are mandatory. Memory-safety roadmaps, pledge goals, and threat-model maturity are recommended or contract-dependent unless law attaches them. Every deliverable from this framework preserves that distinction.

10. Conclusion

Conclusion. Secure-by-design readiness is demonstrable — but only through evidence that is current, technically sufficient, and connected to release decisions. The authorities have converged on that point from four directions at once: NIST’s SSDF supplies the practice vocabulary and is being updated; CISA has turned principles into named goals and named bad practices; SBOM guidance has a 2021 baseline and a 2025 revision in progress; and binding law in the EU, the US medical sector, and the UK has attached dates and duties. The US federal attestation swing — M-22-18 to M-26-05 in three years — is the report’s cautionary lesson: contractual regimes churn, engineering evidence persists. ERC-SbD 1.0 gives product organizations, buyers, and assessors one shared, inspectable structure for producing that evidence. Edition 2 will carry practitioner-validated revisions and the first worked assessments. This framework assesses; it does not certify — and it says so everywhere it matters.

References

Access dates: October 27, 2026 unless noted. The final release will include archived snapshots where permitted.

1. NIST. Secure Software Development Framework (SSDF) project page. https://csrc.nist.gov/Projects/ssdf

2. Souppaya, M., Scarfone, K., and Dodd, P. (2022). Secure Software Development Framework (SSDF) v1.1, NIST SP 800-218. https://csrc.nist.gov/pubs/sp/800/218/final

3. NIST (2025, December 17). Secure Software Development Framework (SSDF) Version 1.2 Available for Public Comment. https://www.nist.gov/news-events/news/2025/12/secure-software-development-framework-ssdf-version-12-available-public

4. NIST SP 800-218 Rev. 1 (SSDF v1.2) initial public draft. https://csrc.nist.gov/pubs/sp/800/218/r1/ipd

5. CISA (2023, April). Shifting the Balance of Cybersecurity Risk: Principles and Approaches for Security-by-Design and -Default. https://www.cisa.gov/sites/default/files/2023-04/principles_approaches_for_security-by-design-default_508_0.pdf

6. CISA. Secure by Design. https://www.cisa.gov/securebydesign

7. CISA. Secure by Design Pledge. https://www.cisa.gov/securebydesign/pledge (pledge PDF: cisa.gov/sites/default/files/2024-05/CISA Secure by Design Pledge 508c.pdf)

8. CISA (2024, May 8). CISA Announces Secure by Design Commitments from Leading Technology Providers. https://www.cisa.gov/news-events/news/cisa-announces-secure-design-commitments-leading-technology-providers

9. CISA (2025, January 13). Building a Secure by Design Ecosystem. https://www.cisa.gov/news-events/news/building-secure-design-ecosystem

10. CISA and FBI (2025, January 17). Product Security Bad Practices (updated guidance). https://www.cisa.gov/news-events/alerts/2025/01/17/cisa-and-fbi-release-updated-guidance-product-security-bad-practices

11. NTIA (2021, July 12). The Minimum Elements For a Software Bill of Materials (SBOM). https://www.ntia.gov/report/2021/minimum-elements-software-bill-materials-sbom

12. CISA (2025, August 22). 2025 Minimum Elements for a Software Bill of Materials (SBOM) — draft for comment. https://www.cisa.gov/resources-tools/resources/2025-minimum-elements-software-bill-materials-sbom

13. Regulation (EU) 2024/2847 (Cyber Resilience Act). https://eur-lex.europa.eu/eli/reg/2024/2847/oj/eng

14. European Commission. Cyber Resilience Act policy pages (updated 2026). https://digital-strategy.ec.europa.eu/en/policies/cyber-resilience-act

15. FDA. Cybersecurity in Medical Devices Frequently Asked Questions (section 524B). https://www.fda.gov/medical-devices/digital-health-center-excellence/cybersecurity-medical-devices-frequently-asked-questions-faqs

16. GOV.UK. The UK Product Security and Telecommunications Infrastructure (Product Security) regime. https://www.gov.uk/government/publications/the-uk-product-security-and-telecommunications-infrastructure-product-security-regime

17. NIST (2022, May 3). Software Security in Supply Chains: Attesting to Conformity with Secure Software Development Practices. https://www.nist.gov/itl/executive-order-14028-improving-nations-cybersecurity/software-security-supply-chains-attesting

18. OMB M-26-05 (2026, January 23). Adopting a Risk-based Approach to Software and Hardware Security. https://www.whitehouse.gov/wp-content/uploads/2026/01/M-26-05-Adopting-a-Risk-based-Approach-to-Software-and-Hardware-Security.pdf

19. CISA (2024, March). Secure Software Development Attestation Form. https://www.cisa.gov/secure-software-attestation-form

20. Regenscheid, A. (2018). Platform Firmware Resiliency Guidelines, NIST SP 800-193. https://csrc.nist.gov/pubs/sp/800/193/final

21. NIST. NIST Technical Series Publications Author Instructions. https://www.nist.gov/nist-research-library/nist-technical-series-publications-author-instructions

Note on source quality: all legal and framework entries are official texts or official landing pages. Commentary and vendor pages are excluded from obligation-content claims entirely.

Appendix A: Evidence-request list

A.1 Universal requests

The last release decision record; the artifact register mapping controls to artifacts; the standards-register snapshot in force for the assessment.

A.2 By domain (abridged; the workbook carries the full list)

• **Governance:** policy with named owner; requirement-traceability entries showing security requirements in product requirements.

• **Architecture:** threat models per product; mitigation tracker linked to requirements.

• **Development:** code-review records; memory-safety roadmap; scan reports; branch-protection configuration.

• **Build:** build-environment access controls; provenance attestations; a reproducible-build demonstration.

• **Dependencies:** per-release SBOMs; screening and triage records.

• **Vulnerability handling:** VDP; intake and triage metrics; CVE records; exercise records for the CRA reporting clocks.

• **Release engineering:** signing procedure; verification logs; release checklists citing security artifacts.

• **Firmware updates:** authentication and anti-rollback test records; support-period policy.

• **Telemetry:** data dictionary; monitoring runbooks; incident-drill records.

• **End of life:** support-period and EOL policy; customer-notification records.

Refusing, or being unable, to produce these items is itself scored evidence.

Appendix B: Assessor interview guide (60–90 minutes)

Opening: scope, confidentiality, evidence-over-assertion framing, consent.

Prompts (six to eight domains per session):

• "Show me the last SBOM you shipped and how it was generated."

• "When the last critical dependency CVE landed, what happened, and where is that recorded?"

• "Who signed the last firmware release, and how does the device verify it?"

• "What happens at end of support — where is that written, and who is notified?"

• "Show me a threat model and one mitigation that shipped because of it."

- "When did a release decision last cite a security artifact?"
- "Rehearse the CRA 24-hour clock: who calls whom?"

Cross-checks: every claim is checked against the Appendix A artifacts; contradictions are recorded under the conflict rule.

Appendix C: Worked exemplar — third-party dependencies and SBOM (domain 5)

Controls 5.1–5.4 at full specification, demonstrating workbook depth; the remaining nine domains receive the same treatment in the workbook.

Table 11. Domain 5 controls at full specification

Control	Objective	Applicability	Expected implementation	Acceptable evidence	Maturity indicators	Responsible function	Common gaps
5.1 Dependency inventory	Know every third-party component in each build	All software-bearing products	Dependency manager of record; lockfiles; vendored-component register	Lockfiles; dependency graph per build	R1 inventory exists; R2 current and used in triage; R3 verifiable against provenance	Build engineering	Undeclared vendored code; stale lockfiles
5.2 SBOM	See Section 6.4 for the full table	—	—	—	—	—	—
5.3 Known-vulnerability screening	Detect known-vulnerable components before release	All	Automated screening against advisories per build and continuously	Screening results per build; triage records	R2: screening in build with findings routed; R3: evidence of a finding fixed via SBOM	Product security	Screening runs but findings untriaged; suppressions without record
5.4 Upstream engagement	Manage dependency risk at source	Where dependencies are third-party maintained	Contribution or upgrade-path policy; maintenance-status tracking	Upgrade policy; maintenance-status register	R2: policy used in decisions; R3: demonstrated upstream fix	Engineering management	Abandoned dependencies carried silently

Appendix D: Management checklist (one page)

1. We can name the executive owner for product security, and the org chart shows it.
2. Every product has a threat model updated within the last two releases.
3. Every release ships with a machine-readable SBOM generated by the build.
4. Our VDP is published, and we can show triage-to-fix metrics for the last quarter.
5. Release artifacts are signed, and our devices verify signatures with anti-rollback.

6. We know our earliest binding regulatory date per market (CRA 2026/2027; FDA submissions; UK PSTI).

7. Release decisions cite security artifacts in a written record.

8. We have published support-period and end-of-life commitments.

9. Our standards register was reviewed within the last quarter (SSDF 1.2 and CISA SBOM statuses).

10. No one in our organization describes any of the above as certification.

Each item maps to domains 1–10; failing items are the remediation list.

Appendix E: Accessibility conformance statement

Target. WCAG 2.2 Level AA plus PDF/UA as the internal ERC standard for public reports.

Implemented in this edition. Letter page size; 0.75-inch margins; 10.5 pt body text left-aligned (not justified); headings implemented as distinct paragraph styles in a two-to-three-level hierarchy (a fourth level is not used); consistent headers and footers carrying the report identifier, version, and page numbers; Unicode-mapped searchable text; live hyperlinks with descriptive text and PDF bookmarks matching the table of contents; document title, author, subject, and keyword metadata set; tables with header rows and grid borders (no layout-only tables), headers repeated across pages; heat-map marks use texture plus shading rather than color alone; minimum 4.5:1 text contrast. One typographic deviation is recorded: third-level headings are set at 11.5 pt bold oblique to preserve visual hierarchy below the 14 pt second-level headings.

Deviations and planned remediation. This edition is generated from a programmatic layout engine that does not yet emit a complete PDF/UA tag tree. Before final release, the PDF will be remediated and validated per the ERC accessibility acceptance process: automated checker, PDF/UA validation (PAC or equivalent), manual tag-tree and reading-order inspection, keyboard and screen-reader sample testing, plain-text extraction review, and a recorded test log. The accessible HTML edition is the canonical reading experience; this PDF serves offline, print, and archival use. An alternate-format contact appears in the document-control section.

Tables. All tables use real header rows, repeated across pages; no figure in this edition relies on color alone.

Appendix F: Assessment operations

Flow (Recommendation). Evidence pack requested (Appendix A) □ artifact review □ interview (Appendix B) □ tier assignment under the anti-gaming rules □ heat map plus the three audience views □ remediation roadmap. Effort (ERC estimate): 3–5 assessor-days for a single-product scope; 8–12 for a multi-product portfolio.

Table 12. Control workbook structure

Sheet	Contents
1 — Controls	All controls across the ten domains with the eight fields and anchors
2 — Tier record	R0–R3 per control with artifact references, confidence labels, and dates
3 — Heat map	Domain and obligation-class tier counts; no weighted scores
4 — Remediation template	Per-control owners, due dates, verification methods
5 — Register snapshot	The standards-register version in force for the assessment

Appendix G: Versioned standards register (detail)

Maintained as a first-class artifact; every assessment records the register snapshot it used.

Table 13. Versioned standards register (full)

Row	Instrument	Version / date	Status	Change-watch trigger
R1	SSDF SP 800-218	v1.1, Feb 2022	Final	v1.2 final publication
R2	SSDF Rev.1	v1.2 IPD, Dec 17 2025	Draft	Final publication; task changes
R3	CISA SbD whitepaper	Apr 2023	Published	Revisions
R4	CISA SbD Pledge	May 2024	Active	Goal changes; report-out requirements
R5	CISA/FBI Bad Practices	Jan 17 2025	Published	Additions
R6	NTIA SBOM elements	Jul 12 2021	Final (baseline)	CISA finalization
R7	CISA 2025 SBOM elements	Draft, Aug 22 2025	Draft	Finalization
R8	NIST SP 800-193	May 2018	Final	Revision or companion publication
R9	EU CRA 2024/2847	In force Dec 10 2024	Binding law	Implementing acts; harmonized standards
R10	FDA 524B guidance	FAQ updated Jun 2025	Binding law	Premarket guidance revisions
R11	UK PSTI regime	Effective Apr 29 2024	Binding law	Scope expansion
R12	OMB M-22-18 / M-23-16	2022 / 2023	Rescinded (Jan 2026)	Successor policy changes
R13	OMB M-26-05	Jan 23 2026	Current	Agency implementation guidance

Appendix H: Obligation-type classification detail (ERC analysis)

Worked classifications for ten frequent questions; counsel is required for product-specific determinations.

• **SBOM delivery to EU customers after December 2027** — law (CRA) where required for the product class.

• **SBOM to a US agency today** — contract-dependent; the federal attestation mandate was rescinded, but agencies may still request artifacts under M-26-05.

• **VDP publication for UK consumer connectables** — law (PSTI).

• **Memory-safety roadmap** — voluntary (CISA pledge) unless contractually invoked.

• **Signed firmware updates for EU-market products** — law (CRA essential requirements).

• **Threat modeling** — voluntary (SSDF PW); contractually required for some suppliers.

• **Support-period publication for EU products** — law (CRA).

• **Telemetry minimization** — law as to data protection (CRA and GDPR interplay); telemetry-for-security design is [ERC-proposed].

• **Attestation of SSDF conformity** — contract-dependent, and only with the understanding that the federal mandate was rescinded.

• **"We are certified secure by design"** — unsupportable under this framework; no such certification exists here.

Appendix I: Lead-control specifications for the remaining nine domains

The lead control of each domain is stated here at the full eight-field depth used in the workbook (domain 5 appears in Section 6.4 and Appendix C). Every field is ERC framework content anchored to the cited authorities; bracketed labels mark ERC-proposed content.

Table 14. Lead-control specifications, domains 1–4 and 6–10

Domain / control	Objective	Applicability	Expected implementation	Acceptable evidence	Maturity indicators	Responsible function	Common gaps
1.1 Executive ownership of product-security outcomes	Make security a business requirement with a named accountable owner	All product organizations	Security policy names the owner; security requirements flow into product requirements with traceability	Policy naming the owner; org-chart evidence; traceability entries	R1 policy exists; R2 cited in release records; R3 externally attested with artifacts	Executive leadership	Policy without a named owner; security requirements absent from product specifications

Domain / control	Objective	Applicability	Expected implementation	Acceptable evidence	Maturity indicators	Responsible function	Common gaps
2.1 Threat model per product and major release	Identify and mitigate design-level threats before build	All products; depth scales with exposure	Threat modeling at design time; mitigations tracked to closure and tested	Threat-model artifacts; mitigation tracker linked to requirements	R1 model exists; R2 updated within two releases and cited; R3 independently reviewed	Security architecture	Model written once, never updated; mitigations untracked
3.1 Secure-coding standards and memory-safety roadmap	Reduce exploitable defect classes at the source	All software development	Standards enforced in review; memory-safe language roadmap with dated milestones	Standards document; roadmap; code-review records	R1 documented; R2 enforced with review evidence; R3 roadmap milestones met	Engineering management	Standards not enforced; roadmap without dates
4.1 Hardened build environment with provenance	Ensure artifacts are built from known, protected environments	All products with automated builds	Access-controlled build service; logs; provenance produced per artifact	Access-control records; build logs; provenance attestations	R1 logging; R2 access controls evidenced; R3 provenance independently verified	Build and CI engineering	Shared credentials; unlogged manual builds
6.1 Published VDP and triage SLAs	Receive, triage, and fix vulnerabilities predictably	All network-exposed products; mandatory for UK consumer connectables	Published VDP; staffed intake; triage and remediation SLAs; CVE issuance practice	VDP; triage metrics; CVE records; clock-exercise records	R1 VDP; R2 metrics show SLA performance; R3 external validation of handling	Product security and incident response	VDP without staffing; SLAs never measured
7.1 Signed release artifacts with verification	Ensure shipped artifacts are authentic and untampered	All firmware-bearing and software products	Signing procedure; device-side verification; release checklist citing security checks	Signing procedure; verification logs; release records	R1 signing exists; R2 verification evidenced and release-cited; R3 provenance-anchored	Release management	Signing skipped for internal builds that ship; no device-side verification
8.1 Authenticated firmware updates with anti-rollback	Deliver fixes safely throughout the support period	Connected and firmware-bearing products	Signed update packages; rollback protection; staged delivery process	Update test records; rollback-protection evidence; support-period policy	R1 mechanism exists; R2 tested per release; R3 independent resiliency verification	Firmware engineering	Updates unsigned; rollback possible; support period unpublished
9.1 Security-relevant telemetry with privacy-preserving collection	Detect in-field compromise and feed response [ERC]	Connected products with connectivity	Defined telemetry dictionary; privacy review; monitoring runbooks and drills	Data dictionary; runbooks; drill records	R1 dictionary; R2 monitoring operational with drills; R3 detection demonstrated	Product security and operations	Telemetry collected but unmonitored; privacy review missing

Domain / control	Objective	Applicability	Expected implementation	Acceptable evidence	Maturity indicators	Responsible function	Common gaps
10.1 Published support-period and end-of-life policy	Customers can plan; obligations end predictably	All products with connectivity or update obligations	Published support period; EOL process; decommissioning and data-clearing guidance	EOL policy; last-update commitments; notification records	R1 policy; R2 commitments honored and dated; R3 notification demonstrated	Product management and security	EOL undefined; data not cleared at decommission

Appendix J: Worked tier-assignment example and procurement language (ERC-constructed)

(Illustrative example constructed by ERC for exposition; not a description of any real organization.) Consider control 6.1 (VDP and triage SLAs) assessed at a mid-size IoT manufacturer.

Table 15. Worked example: control 6.1 tier assignment

Criterion	Observed	Tier effect
VDP published and reachable	Yes — public page with intake address	Satisfies R1
VDP current and staffed	Intake inbox monitored; no named owner; no SLA numbers published	R2 gate 2 fails (no named role, no measurable SLA)
Triage-to-fix metrics recorded	Metrics exist for the last quarter in the defect system	R2 evidence once a named owner is recorded
Release decision cites the metrics	No record found	R2 blocked; tier capped at R1 under the anti-document rule
Independent verification	Not attempted	R3 unavailable

Assignment: R1 with remediation note — name the owner, publish SLA numbers, and start the decision-citation log to reach R2. The workbook performs exactly this arithmetic.

Sample procurement language (ERC-proposed, adapt with counsel). "Supplier shall deliver, for each software or firmware release: (a) a machine-readable SBOM meeting the NTIA minimum elements or successor guidance; (b) evidence of automated known-vulnerability screening with triage records; (c) signing and verification procedures for all artifacts; (d) the vulnerability disclosure policy in force; and (e) a support-period statement. Evidence is accepted as current when dated within one release cycle and referenced in a release record."

Appendix K: Cross-framework mapping (domain to SSDF, CISA, and law)

The mapping table is the assessor’s navigation aid: for each domain, where the authoritative requirements live. It also exposes the framework’s coverage logic — domains 8–10 exist because binding law reaches into product lifecycle territory that development-focused frameworks do not cover.

Table 16. Cross-framework mapping by domain

Domain	SSDF practice groups	CISA instruments	Binding law	SBOM guidance
1 Governance and accountability	PO (esp. PO.1, PO.2)	SbD principles (ownership; top-down approach)	—	—
2 Architecture and threat modeling	PW.1	SbD principles (design-phase investment)	—	—
3 Secure development	PW.4–PW.8	Pledge goals (memory safety, secrets); Bad Practices	—	—
4 Build systems and provenance	PO.5, PS.2	SbD principles	—	—
5 Dependencies and SBOM	PS.3, PW.4	Bad Practices (third-component risk)	FDA 524B(b); CRA Annex I	NTIA 2021; CISA 2025 draft
6 Vulnerability handling and disclosure	RV.1–RV.4	Pledge goal 3 (VDP); Bad Practices	UK PSTI; FDA 524B; CRA Art. 14	—
7 Release engineering and signing	PS.3, PW.11	—	CRA essentials (integrity)	—
8 Firmware update mechanisms	PW.11 (partial)	—	CRA essentials (updates, rollback); UK PSTI	—
9 Telemetry and monitoring	— (limited; RV support)	—	CRA Art. 14 reporting readiness; data-protection law	—
10 End-of-life planning	—	—	CRA support-period duty; UK PSTI	—

Mappings are ERC analysis of the cited instruments; clause-level mapping for a specific product is assessment work, and SSDF identifiers follow v1.1 numbering pending v1.2 finalization.

Appendix L: Assessment scope tiers

The framework supports three engagement scopes so the cost of assessment matches the decision it serves. All scopes use the same controls and gates; only breadth differs.

Table 17. Assessment scope tiers

Scope	What is assessed	Typical effort	Serves
Vital-signs lite	Domains 1, 5, 6, 7, 8 at lead-control depth; obligation-class inventory	1–2 assessor-days	Board briefing; supplier pre-qualification
Single-product standard	All ten domains for one product line, all controls at workbook depth	3–5 assessor-days	Procurement decisions; regulatory-readiness checks

Scope	What is assessed	Typical effort	Serves
Portfolio diligence	All ten domains across the product portfolio with per-product applicability maps	8–12 assessor-days	M&A; and investment diligence; multi-market compliance planning

Every scope applies the same anti-gaming rules, confidence labels, and conflict rule; scope never relaxes evidence standards, only their breadth. Scope selection is recorded in the workbook so results are comparable across engagements.

Appendix M: Executive heat-map mock-up

The executive deliverable is a one-page heat map in this structure. In the published PDF, the attained tier is marked with a filled cell carrying a distinct texture or symbol in addition to shading (never color alone); each row carries the decisive artifact reference and an evidence-confidence label. The mock below uses an illustrative profile.

Table 18. Executive heat-map structure (illustrative profile)

Domain	R0	R1	R2	R3	Confidence	Decisive artifact
1 Governance	—	—	[X]	—	Direct	Security policy v3.2; release record RR-118
2 Architecture	—	[ ]	—	—	Claimed (capped)	Threat model claimed, not shown
3 Secure development	—	—	[X]	—	Direct	Review records; roadmap v1
4 Build and provenance	—	—	[ ]	—	Attested	Access-control screenshot; logs
5 Dependencies and SBOM	—	—	—	[X]	Direct	Per-release SBOMs; provenance check
6 Vulnerability handling	[ ]	—	—	—	Direct	VDP live; no owner named (Appendix J)
7 Release engineering	—	—	[X]	—	Direct	Signing procedure; verification logs
8 Firmware updates	—	[ ]	—	—	Attested	Update tests claimed for one release
9 Telemetry	[ ]	—	—	—	Direct	Dictionary exists; no runbooks
10 End of life	[ ]	—	—	—	Direct	No published support period

Reading rules for executives: the profile is the finding — six domains at R2 or better alongside four at R0–R1 means the organization can ship evidence for some claims and not others; obligation-class coloring (law versus voluntary) is added in the workbook view; and no single grade is ever computed. The filled-cell marks use distinct textures per tier so the profile survives grayscale printing and screen-reader table navigation.

Glossary and acronyms

Attestation — a formal, signed statement of conformity with practices, typically to buyers. **CRA** — EU Cyber Resilience Act (Regulation (EU) 2024/2847). **CVE** — Common Vulnerabilities

and Exposures identifier. **DevSecOps** — development practice integrating security into development and operations pipelines. **EO 14028** — US Executive Order 14028 on Improving the Nation's Cybersecurity (May 2021). **Provenance** — verifiable metadata about how an artifact was built. **PS / PW / PO / RV** — SSDF practice groups. **PSTI** — UK Product Security and Telecommunications Infrastructure Act 2022 regime. **SBOM** — software bill of materials. **SbD** — secure by design and secure by default. **SSDF** — NIST Secure Software Development Framework. **524B** — section 524B of the US Federal Food, Drug, and Cosmetic Act (cyber devices). **VDP** — vulnerability disclosure policy. **R0–R3** — the framework readiness tiers.

Change log

Table 19. Version history

Version	Date	Change
1.0	2026-10-27	Initial public draft: ten-domain framework; control-to-evidence matrix; readiness tiers with anti-document rule; three audience views; versioned standards register through M-26-05.
1.0a	2026-10-28	Production remediation: embedded TrueType typefaces; document language (en-US) declared in the PDF catalog; accessibility pre-test record published; companion accessible HTML edition generated; Section 7 retitled to the standard's Analysis element with a competing-interpretations subsection added.
1.1 (planned)	On SSDF v1.2 finalization	Re-base control cross-references; update register.
2.0 (planned)	2027	Practitioner-validated revisions; first worked assessments; CRA-readiness case studies ahead of December 2027.

Data and code statement

The control workbook (XLSX/CSV) and management checklist will be published on the ERC canonical report page for ERC-RPT-2026-004 under CC BY 4.0, with scripts under an OSI-approved license. This edition contains no organization-specific data. Assessment records remain confidential to clients; only anonymized aggregates publish, with consent. The versioned standards register is maintained in the workbook and updated publicly on the canonical page when referenced instruments change.

Corrections. Corrections, replacement versions, the workbook, and the checklist will be posted on the canonical ERC report page identified in the document-control section. Readers who identify an error may contact ERC through that page.